

MEDUSA LSA SECURITY PACKAGE REGISTRATION

Source-observed registration of the Mimikatz mimilib Security Support Provider for plaintext credential capture.

PRODUCTION CANDIDATE

CONFIDENCE: MEDIUM

SOURCE-CONFIRMED BEHAVIOR

retain facts, isolate interpretation

DeviceRegistryEvents

direct telemetry boundary

HUNT · VALIDATE · TUNE

no automatic malicious verdict

REPORT DATE

19 August 2026

VERSION

v1.0

PRIMARY TELEMETRY

Microsoft Defender XDR ·
DeviceRegistryEvents

ATT&CK

T1547.005

Evidence-led dossier. Query status remains an untested implementation sketch until executed in the target environment.

INDEPENDENT RESEARCH FORMAT · CONTROLLED UI/UX MASTER



EXECUTIVE ASSESSMENT

Decision-grade summary for detection engineering and SOC operations.

ASSESSMENT

EXECUTIVE SUMMARY

Detect the exact credential-persistence Registry modification.

CISA, FBI and HHS report that Medusa actors add mimilib to the LSA Security Packages REG_MULTI_SZ value. Microsoft Defender for Endpoint exposes the affected key, value name, value data and writer context in DeviceRegistryEvents.

OPERATIONAL VALUE

High-signal behavior with an explicit evasion boundary.

Loading an unapproved SSP into LSASS creates credential access and persistence risk. The exact library name is tool-specific and mutable, but benign use of mimilib in production should be exceptional and independently verifiable.

9.4

01

OPERATIONAL VALUE



Medium

02

DETECTION CONFIDENCE



Candidate

03

OPERATIONAL READINESS



SOURCE-CONFIRMED FACTS

Observed behavior

- The advisory was updated on 18 August 2026 with FBI investigations through April 2026.
- Medusa actors used Mimikatz mimilib.dll against the LSA authentication mechanism.
- The reported command appends mimilib to the LSA Security Packages value.
- The reported module records plaintext passwords in C:\Windows\System32\kiwissp.log.

ANALYTICAL ASSESSMENT

What the evidence supports

- The Registry event is the earliest directly observable configuration signal in the documented behavior.
- A match warrants urgent containment-oriented validation because the change can persist across reboot.
- Attribution and successful credential capture require additional evidence.

DETECTION ASSUMPTIONS

What must be validated

- MDE Registry telemetry is enabled, retained and records the new REG_MULTI_SZ data.
- RegistryValueData contains the complete post-change value.
- No approved production workload deliberately deploys Mimikatz mimilib.

Confidence boundary

The rule does not detect a renamed SSP, memory-only installation, direct AddSecurityPackage API use without a Registry event, successful DLL loading, kiwissp.log creation, password capture or ransomware execution.



THREAT MECHANICS

Source-observed chain and explicit observability boundaries.

ATTACK FLOW

01

Privileged access

The actor reaches a Windows system with rights to modify HKLM.

02

SSP staging

mimilib.dll is placed where LSA can load it.

03

Registry change

mimilib is added to LSA Security Packages.

04

LSASS load

The SSP is loaded at boot or through the security-package API.

05

Credential capture

Authentication secrets may be written to kiwissp.log.

Observable core

A Registry event for the LSA Security Packages value whose recorded data contains mimilib.

Non-observable boundary

DLL contents, successful LSASS load, captured passwords, kiwissp.log contents, lateral movement and Medusa attribution.

DETECTION HYPOTHESIS

Credential-persistence registration should be visible in Registry telemetry.

If an attacker registers the source-observed mimilib SSP, DeviceRegistryEvents should record the LSA Security Packages value with mimilib in RegistryValueData. Approved lab scope, change records, host role, module provenance and writer context distinguish authorized testing from compromise.

REQUIRED TELEMETRY

DeviceRegistryEvents

- Microsoft Defender for Endpoint Registry events.
- RegistryKey, RegistryValueName and RegistryValueData.
- Device and event identifiers.

OPTIONAL ENRICHMENT

Context that improves disposition

- PreviousRegistryValueData and RegistryValueType.
- Writer process path, command line, account, hash and unique ID.
- File, image-load, process and log-file telemetry.

UNAVAILABLE HERE

Do not infer

- SSP DLL contents from the Registry event.
- Passwords or kiwissp.log contents.
- Proof that LSASS loaded the module or Medusa operated it.



TELEMETRY & EVIDENCE MODEL

Minimum data contract and quality gates for a defensible hunt.

DATA CONTRACT

PRIMARY DATA SOURCE

Microsoft Defender XDR · DeviceRegistryEvents

DeviceRegistryEvents records Registry creation and modification activity from Microsoft Defender for Endpoint, including the affected key, value data and initiating-process context.

EVIDENCE BOUNDARY

A matching event is a lead, not a verdict.

A match proves that collected Registry value data contained mimilib. It does not prove the module loaded, credentials were captured or the activity belongs to Medusa.

REQUIRED AND ENRICHMENT FIELD MODEL

CATEGORY	FIELD	PURPOSE	REQUIREMENT
Registry event	DeviceRegistryEvents	Native MDE Registry telemetry.	REQUIRED
Registry path	RegistryKey	LSA configuration location.	REQUIRED
Value name	RegistryValueName	Security Packages selector.	REQUIRED
Value data	RegistryValueData	Direct mimilib evidence.	REQUIRED
Event identity	Timestamp, ReportId	Investigation and deduplication.	REQUIRED
Device	DeviceId, DeviceName	Endpoint pivot.	REQUIRED
Prior state	PreviousRegistryValueData	Determine whether mimilib was newly appended.	OPTIONAL
Writer	InitiatingProcessFileName, InitiatingProcessCommandLine	Operator and change provenance.	OPTIONAL

Data quality requirements

- Confirm MDE onboarding and Registry-event retention.
- Replay a safe REG_MULTI_SZ change on an isolated host.
- Verify full multi-string data and previous value population.
- Inventory authorized SSPs and security-test tooling.

Known failure conditions

- MDE is absent or Registry events are not retained.
- RegistryValueData is null or truncated.
- The attacker renames mimilib or uses an API-only path.
- The activity predates available retention.



DETECTION LOGIC

Primary-platform logic with every condition traceable to evidence.

PRODUCTION CANDIDATE

DETECTION OBJECTIVE

Identify the reported LSA credential-persistence configuration.

Select Registry events against the LSA Security Packages value when the recorded value data contains the source-observed mimilib package name.

ANALYTICAL LOGIC

Direct filters and investigable output.

Three direct predicates: documented key suffix, documented value name and source-observed package string. No ActionType assumption, join, sequence, threshold, rarity or aggregation.

KQL · UNTESTED CANDIDATE

```
// Production candidate - Untested implementation sketch
// Primary platform: Microsoft Defender XDR / Advanced Hunting
// Required telemetry: Microsoft Defender for Endpoint registry events on Windows
// Evidence: CISA, FBI and HHS report Medusa actors adding mimilib to the LSA
// Security Packages REG_MULTI_SZ value so the credential-stealing SSP loads in LSASS.
// Detection boundary: a match proves the Registry value contained "mimilib"; it does
// not prove the DLL loaded, passwords were captured, or Medusa attribution.
DeviceRegistryEvents
| where RegistryKey endswith @"\SYSTEM\CurrentControlSet\Control\Lsa"
| where RegistryValueName =~ "Security Packages"
| where RegistryValueData contains "mimilib"
| project
  Timestamp,
  DeviceId,
  DeviceName,
  ReportId,
  ActionType,
  RegistryKey,
  RegistryValueName,
  RegistryValueType,
  RegistryValueData,
  PreviousRegistryValueData,
  InitiatingProcessFileName,
  InitiatingProcessFolderPath,
  InitiatingProcessCommandLine,
  InitiatingProcessAccountName,
  InitiatingProcessSHA1,
  InitiatingProcessUniqueId
| order by Timestamp desc
```

STATUS	THRESHOLD	JOIN / SEQUENCE	PRIMARY KEY	DISPOSITION
Untested candidate	None	None	DeviceName + Timestamp + ReportId	Manual triage

What a match means

The endpoint recorded an LSA Security Packages value containing mimilib and requires immediate raw-event, change-control and module-provenance review.

What a match does not prove

DLL load, password capture, kiwissp.log creation, lateral movement, encryption activity or Medusa attribution.



TRIAGE & INVESTIGATION

Evidence collection before escalation.

SOC WORKFLOW

NUMBERED WORKFLOW

- 01

Confirm the raw event.
Validate complete key, value name, data, previous data and identifiers.
- 02

Assess authorization.
Check host role, change ticket, test window and operator account.
- 03

Collect the module.
Locate mimilib.dll; review path, hash, signature, compile metadata and prevalence.
- 04

Inspect the writer.
Review process ancestry, command line, account, remote session and adjacent actions.
- 05

Scope follow-on.
Hunt for LSASS module load, kiwissp.log, credential use and lateral movement.

Escalation gate

Escalate immediately when mimilib is unauthorized, newly appended, staged from an unusual path, written by an unexplained privileged process, or accompanied by module-load, kiwissp.log or credential-use evidence.

Primary benign overlap

Controlled red-team, forensic or malware-analysis exercises may deploy mimilib. A durable exception must bind to isolated assets, approved time windows, operators and change records; never allowlist reg.exe globally.

INVESTIGATION PIVOTS

Host
Role, exposure, privileged sessions and neighboring alerts.

Registry
Previous value and other LSA package changes.

Module
Path, hash, signer, prevalence and first seen.

Writer
Process ancestry, command line, account and remote origin.

Credential artifact
kiwissp.log file activity without collecting its sensitive contents.

Identity
Subsequent authentication and lateral-movement evidence.

DISPOSITION CRITERIA

OUTCOME	MINIMUM EVIDENCE	ACTION
BENIGN	Approved, owned and repeatable activity.	Document and tune narrowly.
SUSPICIOUS	Unknown activity without corroborated malicious follow-on.	Deepen endpoint review.
LIKELY MALICIOUS	Unauthorized match plus coherent file, process, network or control-plane evidence.	Escalate incident response.



FALSE POSITIVES & VALIDATION

Operational controls required before promotion.

QUALITY GATE

FALSE-POSITIVE MATRIX

SCENARIO	WHY IT OVERLAPS	TUNING ACTION
Authorized security exercise	A red team may reproduce the Mimikatz SSP technique.	Require approved scope, isolated asset, named operator and test window.
Malware-analysis laboratory	Researchers may register mimilib on disposable systems.	Exclude only inventoried lab assets with documented purpose.
Legacy or custom SSP	Organizations may have legitimate SSPs, but exact mimilib overlap should be rare.	Validate package inventory and publisher; do not suppress other SSP changes.

Baseline plan

- Search all available Registry-event retention.
- Inspect every match and associated previous value.
- Inventory approved LSA Security Packages entries.
- Measure value-data and writer-field completeness.

Validation procedure

- Replay a safe disposable Registry change in an isolated endpoint.
- Verify REG_MULTI_SZ normalization and case behavior.
- Execute all three negative controls.
- Review historical matches with identity and endpoint owners.

TEST CASES

CASE	EXPECTED RESULT
Append mimilib in an isolated Windows lab	Expected match with complete Registry value data and writer context.
Modify another LSA value	No match.
Modify Security Packages without mimilib	No match.
Create a mimilib-named value outside the LSA key	No match.

Hunting Initial query	Candidate Current status	Production Measured precision	Optimized Stable feedback
---------------------------------	------------------------------------	---	-------------------------------------

Success

The controlled positive replay matches, negative controls do not, required fields are complete, and historical matches are absent or strictly attributable to approved isolated testing.

Rejection

Registry value data is not collected or legitimate production activity repeatedly uses exact mimilib without a durable discriminator.

Failure

DeviceRegistryEvents is absent, the value is truncated, or the controlled modification produces no usable event.



ATT&CK, CONCLUSION & REFERENCES

Coverage statement, residual risk and document control.

CLOSURE

MITRE ATT&CK MAPPING

TECHNIQUE	NAME	COVERAGE STATEMENT
T1547.005	Boot or Logon Autostart Execution: Security Support Provider	Directly covers modification of the LSA Security Packages configuration to load an SSP. The reported purpose also supports T1003.001 for LSASS credential access, but the query observes registration rather than successful dumping.

Detection coverage summary

Strong for the exact mimilib Registry value; weak for renamed modules, alternate LSA keys, API-only installation, uncollected data and memory-only techniques.

Residual risk

The actor can rename the DLL, use OSConfig, call AddSecurityPackage directly, tamper with telemetry or capture credentials through other LSASS methods. File and image-load telemetry should complement this rule.

ANALYST CONCLUSION

A defensible production candidate grounded in direct government evidence.

The updated advisory provides the exact Registry command and credential-stealing purpose, while Microsoft documents every field used. The three predicates are specific and require no arbitrary threshold. Target-environment replay, value normalization and approved-SSP inventory remain mandatory before alerting.

REFERENCES

- CISA, FBI and HHS, “#StopRansomware: Medusa Ransomware,” Product ID AA25-071A; original 12 March 2025, last updated 18 August 2026; investigations through April 2026. <https://www.fbi.gov/ia/c3a/2026/260818.pdf>
- Microsoft Learn, “DeviceRegistryEvents table in the advanced hunting schema,” updated 11 June 2025; accessed 19 August 2026. <https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceregistryevents-table>
- MITRE ATT&CK, T1547.005, Security Support Provider; accessed 19 August 2026. <https://attack.mitre.org/techniques/T1547/005/>
- MITRE ATT&CK, T1003.001, LSASS Memory; accessed 19 August 2026. <https://attack.mitre.org/techniques/T1003/001/>

DOCUMENT CONTROL

VERSION	DATE	STATUS	OWNER
v1.0	19 August 2026	Candidate	Detection Engineering

Publication control

Eight A4 pages. URLs are defanged. No customer data, credentials, HTML source or rendering assets are included in the public repository.